

ZIMREAPER ZIMBRA APP PASSWORD

A raw-audit hunting model for attacker-created application passwords that bypass mailbox two-factor authentication.

HUNTING

CONFIDENCE: MEDIUM

**REPORT DATE**

24 July 2026

VERSION

v1.0

PRIMARY TELEMETRY

Splunk · Zimbra /opt/zimbra/
log/audit.log

ATT&CK TACTICS

Persistence · Credential
Access

Operational research dossier. All implementations are untested sketches
and require target-environment validation.



EXECUTIVE ASSESSMENT

Decision-grade summary for SOC and detection engineering.

ASSESSMENT LAYER

EXECUTIVE SUMMARY

ZimReaper Zimbra App Password Persistence

Proofpoint observed ZimReaper invoking Zimbra's CreateAppSpecificPasswordRequest to create an app-specific password named ZimbraWeb. That credential enables IMAP, POP3 or SMTP access without the victim's second factor. Proofpoint explicitly recommends reviewing /opt/zimbra/log/audit.log for the operation.

WHY IT MATTERS

Operational value 8.8 / 10

The audit operation and attacker-chosen password label are directly tied to the persistence action. The exact label is campaign-specific, so the query remains hunting rather than a durable production rule.

Medium01

CONFIDENCE

8.802

OPERATIONAL VALUE

Hunting03

READINESS

SOURCE-CONFIRMED FACTS

- ZimReaper invokes CreateAppSpecificPasswordRequest.
- The observed application-password name is ZimbraWeb.
- Proofpoint recommends reviewing /opt/zimbra/log/audit.log for these calls.

ANALYTICAL ASSESSMENT

- The combination of operation and label is a precise campaign hunt.
- The label can be changed, so it must not be treated as durable behavior.
- A match requires validation against user-initiated app-password creation.

ASSUMPTIONS

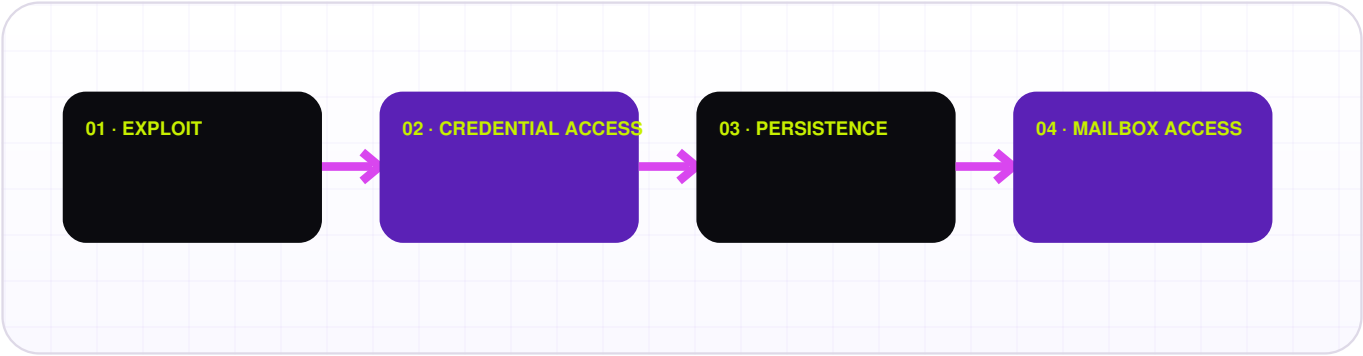
- Zimbra audit.log is ingested without truncation.
- The raw event preserves the operation and application-password name.
- The Splunk source path or sourcetype is customer-specific and must be verified.

02

THREAT MECHANICS

Source-observed chain and detection value.

EVIDENCE FLOW



THREAT MECHANICS AND VISIBILITY

STAGE	BEHAVIOR	OBSERVABLE EVIDENCE	VALUE
Exploit	Stored XSS executes when a vulnerable Zimbra message is opened	Webmail content and network controls	Low
Credential access	Script gathers password, CSRF token and 2FA material	Browser-resident activity; EDR visibility limited	Low
Persistence	CreateAppSpecificPasswordReq uest creates ZimbraWeb	Zimbra audit.log	High
Mailbox access	App password permits IMAP, POP3 or SMTP access	Protocol authentication logs	Medium

Evidence boundary

The report does not infer unseen payload content or compromise outcome. Every query targets the directly observable behavior identified above.



TELEMETRY AND EVIDENCE MODEL

Required data, fields and visibility constraints.

TELEMETRY

PRIMARY DATA SOURCE

Splunk · Zimbra /opt/zimbra/log/audit.log

The selected platform provides the most direct observable for the behavior. Optional enrichment must not be treated as guaranteed.

REQUIRED QUALITY

Complete raw values and stable entity context

Retention, truncation, parsing and sensor coverage must be confirmed before operational deployment.

REQUIRED FIELDS

FIELD	RELIABILITY	PURPOSE
_time	Documented	Splunk event time
host	Documented	Zimbra server identity
source	Environment-dependent	Expected audit.log path
sourcetype	Environment-dependent	Customer parser identifier
_raw	Documented	Operation and label preservation

Required

The primary event, host identity and directly filtered values.

Optional enrichment

Signer, prevalence, parent lineage, network activity or ownership context when available.



DETECTION LOGIC

Primary-platform implementation and condition rationale.

UNTESTED SKETCH

DETECTION OBJECTIVE

ZimReaper Zimbra App Password Persistence

Surface the source-observed behavior with the minimum defensible conditions.

STATUS

Hunting - Untested implementation sketch

No query in this dossier has been executed in the target environment.

KQL · DEMONSTRATIVE

```
index=<CUSTOMER_INDEX> source="/opt/zimbra/log/audit.log"
("CreateAppSpecificPassword" OR "CreateAppSpecificPasswordRequest")
"ZimbraWeb"
| table _time host source sourcetype _raw
```

REVIEW FIELDS · BASELINE LOCALLY · VALIDATE BEFORE PRODUCTION

WHY EACH CONDITION EXISTS

CONDITION	REASON
Audit source	Scopes the hunt to the file Proofpoint explicitly identifies.
Operation string	Represents creation of an app-specific password.
ZimbraWeb	Matches the source-observed attacker label; it is campaign-specific.
No threshold	A single matching persistence operation is investigable.

05

TRIAGE AND INVESTIGATION

Evidence collection and disposition workflow.

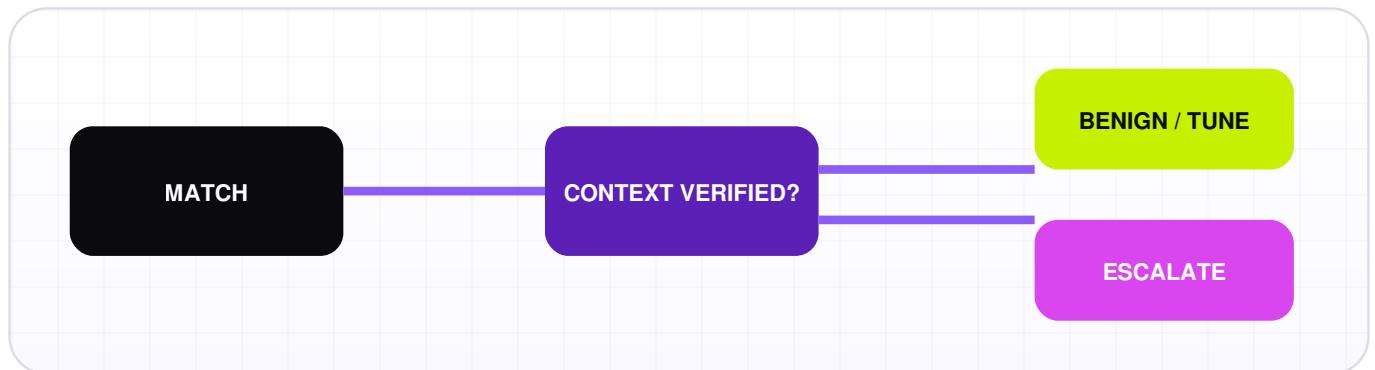
SOC WORKFLOW

- 01 Confirm telemetry**
Confirm that audit.log is ingested and that both operation and password label remain in _raw.
- 02 Reproduce safely**
Create an authorized test app password and compare raw event syntax and actor fields.
- 03 Investigate context**
Measure all app-specific password creation over 90 days before generalizing beyond ZimbraWeb.
- 04 Apply decision gate**
Correlate hits with IMAP, POP3 or SMTP authentication only after identifiers are verified.

INVESTIGATION PIVOTS

Host · user · process · file · network · identity

- Validate actor or parent identity.
- Collect full raw event and surrounding timeline.
- Confirm software owner and change context.
- Review adjacent endpoint, identity and network evidence.
- Preserve hashes and stable event identifiers.





FALSE POSITIVES AND VALIDATION

Baseline, test plan and operational promotion gate.

VALIDATION

FALSE-POSITIVE MATRIX

EXPECTED OVERLAP	LIKELIHOOD	TUNING ACTION
Legitimate user-created app password named ZimbraWeb	Low	Confirm account owner, request context and creation source.
Test or migration tooling	Low	Validate change window and administrator identity.
Parser duplication	Low	Deduplicate only after confirming event identity and ingestion route.
Renamed attacker password	High gap	Broaden only after baselining all app-password creation events.

SUCCESS CRITERIA

Candidate can be separated from authorized activity

The exact operation and label are present in raw events and legitimate matches are attributable.

REJECTION CRITERIA

Do not promote when evidence remains ambiguous

The audit source is absent, truncated, or does not expose the application-password label.

Promotion gate

Require representative baseline, preserved field semantics, documented exclusions, reproducible tests and analyst-readable output. Otherwise retain the current classification.



ATT&CK, CONCLUSION AND REFERENCES

Coverage summary, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	EVIDENCE BASIS
T1098	Account Manipulation	Mapped only to the directly observed behavior.

ANALYST CONCLUSION

ZimReaper Zimbra App Password Persistence

This is a high-value campaign hunt, not a production detection. The action is directly supported, but the ZimbraWeb label is mutable and the customer-specific audit schema must be validated.

Residual risk

Telemetry gaps, altered attacker artifacts and authorized behavior can reduce precision. A query match is an investigative lead, not proof of compromise or attribution.

REFERENCES

1. Proofpoint Threat Research, "TA488 Targets Zimbra Mailservers with Half-Click Exploits," 23 July 2026.
<https://www.proofpoint.com/us/blog/threat-insight/ta488-targets-zimbra-mailservers-half-click-exploits>

2. Official platform documentation.
<https://help.splunk.com/en/splunk-enterprise/spl-search-reference/9.0/search-commands/search>

3. MITRE ATT&CK Enterprise technique T1098.
<https://attack.mitre.org/techniques/T1098/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	CHANGE SUMMARY
v1.0	24 July 2026	Hunting · Medium	Initial evidence-led dossier; untested implementation sketch.